

AI SECURITY GATEWAY

安全交互守护智能体

Security Guard Agent

给你的业务智能体，装上一道多层安全门卫

绿色免安装版 v1.1.0 · 2026 年 8 月 · 面向 LLM 应用的多层风控网关

目录

CONTENTS · 一页看懂这个系统能做什么

01	背景与痛点	LLM 应用面临哪些安全风险
02	产品定位与防线总览	守护智能体，而不是限制智能体
03	输入防线	把住用户说的话：规则 + 混淆归一 + 多轮语境
04	工具防线	管住 AI 能做的事：白名单 + 参数校验 + 令牌
05	输出防线	护住出去的每一句话：脱敏 + 水印 + 差分隐私
06	反刷评与账号风控	去重 + 聚合限流 + 信誉分 + 风险积分
07	判定引擎	本地 / 云端 / 混合三种模式自由切换
08	审计与溯源	攻击类型标签 + 防篡改哈希链 + 报表导出
09	业务接入	黑箱 SDK，几行代码获得完整防护
10	管理界面与部署交付	Web 后台 + 图形面板 + 绿色 ZIP / Docker
11	性能量化	网关自身开销 <2ms，每请求耗时全程可查
12	质量与验收	67 项自动化测试 + 9 项端到端冒烟验证

01 · 背景与痛点

LLM 应用落地后，安全不再是‘要不要防’，而是‘怎么防’

四大核心风险

- 提示注入 / 越狱 —— 几句‘魔法话术’就能让 AI 吐出不该说的内容
- 数据泄露 —— 身份证、手机号、银行卡号随对话悄悄流出
- 工具滥用 —— AI 被诱导调用删除、转账、提权等高危操作
- 刷单刷评 —— 批量机器人灌水、薅羊毛、恶意打差评

还有多轮诱导：不直接问，铺垫几轮再套出敏感信息

结论：防线必须同时布在输入 — 工具 — 输出全链路，任何一环失守都可能出事。

02 · 产品定位与防线总览

一句话：守护智能体，而不是限制智能体

它是什么

- 位置：站在业务 LLM 与用户 / 工具之间的透明安全网关
- 原则：默认拒绝，逐层验证通过才放行；规则可配置、误拦可调
- 形态：单文件服务 + 图形面板 + 黑箱 SDK，非技术用户也能接入

全链路防线



每一层防线独立可开关、可配置，按你的业务风险等级灵活组合。

核心功能总览

六大防线模块，覆盖 LLM 应用全生命周期

输入检测 关键词 / 正则 / 自然语言三层规则 ，可疑内容大模型兜底	提示注入防御 混淆变体归一化 + 间接注入扫描 + 多轮会话语境分	工具调用防护 高危工具拦截 + 白名单授权 + 参数深度校验 + JWT 令牌
输出防护 10 类信息动态脱敏 + 零宽字符水印 + 差分隐私噪声	反刷评风控 内容去重 + 账号 / IP 聚合限流 + 信誉分 + 机器行为检测	审计溯源 攻击类型标签 + 防篡改哈希链 + CSV 报表 + 只读 Token

每个模块都经过自动化测试验证，可单独开关，随业务需要逐步启用。

03 · 输入防线：把住用户说的话

四层机制协同，识别并拦截恶意输入

三层规则引擎

- 关键词规则（rules.txt）：直接命中即拦截，可随时增删
- 内置正则规则：身份证号、手机号、危险命令等自动识别
- 自然语言规则（nlp_rules.json）：'描述意图'自动生成规则，热加载生效

对抗混淆归一化

- 全角字符、多余空格、零宽字符、多层 Base64、URL 编码
- 先归一化解码再检测 —— '忽略规则'这类变体照样识别

多轮渐进式注入防御

- 铺垫词累积'会话语境分' → 达标后升级审查 → 敏感请求联动拦截
- 低风险内容自动改写（可选）：手机号等 PII 先脱敏再放行对话

04 · 工具防线：管住 AI 能做的事

四步把关，高危操作层层设卡

调用前四步检查

- 第一步 白名单：不在白名单的工具直接拦截（高危工具必拦）
- 第二步 参数清洗：内置工具按允许键过滤，防注入多余参数
- 第三步 深度校验：SQL 注入 / 路径遍历 / 批量操作 / 敏感参数
- 第四步 授权令牌：生成 30 秒有效的 JWT，工具端可自证授权

工具结果回传也设防（间接注入）

- 网页 / 文档等工具返回内容可能携带恶意指令
- 返回内容进模型上下文前先扫描，命中即拦截

05 · 输出防线：护住出去的每一句话

脱敏 + 水印 + 差分隐私，三道保险

动态分级脱敏（10 类信息）

- 手机号、身份证、银行卡、邮箱、IP、姓名、地址、车牌、营业执照、微信号
- 示例：13212345678 → 132****5678，按角色策略（full / partial / minimal）分级

零宽字符水印（泄露可溯源）

- 每份输出嵌入肉眼不可见的唯一身份标记
- 一旦内容外泄，提取水印即可定位到会话与用户

差分隐私（可选）

- 对统计数字加入 Laplace 噪声，防止从聚合结果反推个体数据
- 适合‘本月销量多少’这类统计型输出的场景

06 · 反刷评与账号风控

让机器灌水、批量薅羊毛无处遁形

四重反刷机制

- 内容去重：相同 / 相似内容在时间窗内重复提交即拦截
- 聚合限流：账号维度 + IP 维度双重限流，突增流量自动限速
- 信誉分：跨会话累计，行为越差分越低，低到阈值自动限流 / 终止
- 机器行为检测：请求间隔过于均匀 → 疑似自动化脚本

会话风险积分（自动升级处置）

- 30 分警告 → 60 分限流 → 80 分终止
- 拦截行为也累计积分，持续违规会被逐级加压

07 · 判定引擎：安全审核的'大模型法官'

本地 / 云端 / 混合三种模式，GUI 一键切换，配置 3 秒热加载

模式	逻辑	适合场景
本地 local	只用本地 Ollama 模型，数据不出网	金融 / 医疗 / 政务等敏感行业、内网离线
云端 cloud	OpenAI 兼容云端 API，判定能力最强	判定力优先、数据敏感度低的业务
混合 hybrid	本地初筛 + 云端终审，双保险	兼顾隐私与判定力（推荐默认）

引擎不可用时的失败策略

- fallback（推荐）：自动降级到另一引擎，本地 云端互为备份
- block：直接拦截 —— '审核服务不可用'，fail-closed 最安全
- allow：直接放行 —— fail-open，速度快但有风险

08 · 审计与溯源：全程留痕、可校验

日志 100% 可溯源，改动任何一条都能被发现

攻击类型自动标签

- 每条审计记录自动标注：提示注入 / 隐私泄露 / 违规内容 / 滥用 / 未授权工具 / 系统 / 其他

哈希链防篡改

- 每条记录包含上一条的哈希，环环相扣
- 任何人改动任意一条日志，一键'校验完整性'立即暴露

管理能力

- 一键导出 CSV 报表（Excel 直接打开，中文表头）
- 只读 Token：给'只能看、不能改'的同事用，防止误操作
- 按天轮转归档：audit-YYYYMMDD.log，异步写入不丢审计

09 · 业务接入：几行代码搞定

不懂内部机制也能接入 —— 黑箱 SDK

黑箱 SDK（推荐非技术用户）

- 输入审核 → 大模型 → 工具防护 → 输出脱敏水印，自动完成
- 拦截时抛出 GuardBlocked，原因可直接展示给用户
- 连 session / user 标识都不用管，SDK 自动处理

```
from guard_sdk import Guard guard = Guard(api_key="你的密钥") # 一行创建 safe_llm = guard.wrap_llm(my_llm) #  
一行包装你的大模型 reply = safe_llm("用户说的话") # 自动完成全套防护
```

标准 API 同样开放：user_input / tool_call / tool_result / output 四个环节可精细控制。

10 · 管理界面与部署交付

看得见、管得住、拿得走

管理界面

- Web 后台 (/admin)：规则、白名单、会话、审计、水印提取
- 图形控制面板：8 大页签 —— 服务日志 / 业务接入 / 规则管理 / 工具白名单 / 会话监控 / 审计日志 / 系统配置 / 水印提取
- 本地 / 云端 / 混合模式一键切换，DeepSeek 等云端密钥 GUI 内填入

部署交付

- 绿色免安装 ZIP：解压即用，双击「启动GUI.bat」，无需安装 Python / Go
- Docker 镜像约 15MB，多阶段构建，一条命令启动
- 多实例水平扩展时用 Redis 共享会话；单实例完全不需要
- 跨平台：Windows / Linux / macOS 二进制均已构建

11 · 性能量化（Latency）

网关自身开销 <2ms，损耗透明可查

场景	P50	平均	说明
普通输入放行	0.9 ms	0.9 ms	纯规则快速路径，无大模型（keep-alive 长连接实测 100 次）
工具调用放行 / 拦截	1.0 ms	1.1 ms	白名单 + 参数校验 + JWT 令牌
输出脱敏 + 水印	1.2 ms	1.3 ms	10 类信息脱敏 + 零宽水印 + 差分隐私
大模型判定（可选）	~0.9 s	~0.9 s	仅可疑内容 / 强制审查时触发；30 秒判断缓存命中零开销

性能结论

- 网关自身开销（规则检测 / 脱敏 / 令牌等纯本地逻辑）P50 约 1 ms，平均 = 中位，损耗可忽略
 - 长连接接入下平均与 P50 一致（0.9~1.3 ms）；若每次新建连接会叠加约 20ms TCP 握手，属客户端开销
 - 大模型判定引擎是唯一显著开销（约 0.9 s），仅在可疑内容时触发，可开关、可换引擎
- 每请求耗时已全程量化：响应含 latency_ms / llm_ms 字段，审计日志逐条记录，CSV 报表可导出

12 · 质量与验收

每一个功能都经过真实运行验证

验证情况

- 67 项自动化测试全部通过 (go test)
- 端到端冒烟验证 9/9 通过：在真实打包二进制上实测全部新功能
- 示例验证：'请帮我记录号码13212345678' → 放行并返回 132****5678
- 示例验证：同一内容 10 分钟内重复提交 → 防刷屏拦截生效

PRD 核心验收标准

- 越狱识别率 $\geq 98\%$ · 误拦截率 $\leq 1\%$
- 多轮诱导识别率 $\geq 95\%$ · 高危工具拦截率 100%
- 日志 100% 可溯源 (哈希链可校验)

谢谢观看

安全交互守护智能体 · Security Guard Agent · v1.1.0

把 AI 的能力，关进安全的笼子里

绿色免安装版 · 解压即用 · 双击「启动GUI.bat」